

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA
FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN
SEDE EL NARANJO

Curso: Seguridad y Auditoría de Sistemas

Sección: "A"

Catedrático: Omar Sagastume

Proyecto de Curso

MODELO DE SEGURIDAD DE LA INFORMACIÓN AUDITABLE APLICADO A ADSCOPE:
SISTEMA DE GESTIÓN DE PPC Y SEO PARA AMAZON

Integrantes:

Anthony Fabian Ramírez Orellana

Carné: 9490-22-958

Nery Otoniel Colorado Menchú

Carné: 9490-22-4867

Guatemala, septiembre de 2026

Índice

Índice.....	2
Introducción.....	3
1. Modelo de Negocio.....	4
1.1 Planteamiento del Problema (Situación actual)	4
1.2 Objetivos	4
Objetivo General	4
Objetivos Específicos.....	4
1.3 Planificación de la Solución.....	5
2. Modelo de Seguridad.....	6
2.1 Planteamiento del Proyecto de Seguridad	6
2.2 Viabilidad Técnica y Operativa de la Solución	6
Viabilidad técnica	6
Viabilidad operativa	6
Limitaciones reconocidas.....	6
2.3 Contexto Técnico de Trabajo	7
2.3.1 Hardware	7
2.3.2 Software	7
2.3.3 Metodología, estándar, etc.....	7
2.4 Otros Recursos y Consideraciones	8
2.5 Plan de Ejecución	8
2.6 Clasificación de Vulnerabilidad y/o Amenaza.....	10
2.7 Implementación de Estándar ISO/IEC 27001:2022.....	12
Conclusiones y Recomendaciones	14
Conclusiones	14
Recomendaciones	14
Glosario	15
Bibliografía	17

Introducción

El presente proyecto de curso, elaborado para la asignatura de Seguridad y Auditoría de Sistemas de la Universidad Mariano Gálvez de Guatemala, documenta el diseño e implementación de un modelo de seguridad de la información auditable sobre un sistema de software real y en producción: AdScope, una plataforma web para la gestión de campañas publicitarias PPC (Pay-Per-Click) y de optimización de posicionamiento (SEO) de productos vendidos en Amazon.

A diferencia de un ejercicio puramente teórico, el modelo de seguridad descrito en este documento no se limita a políticas en papel: cada control fue efectivamente implementado en código fuente, desplegado en infraestructura en la nube y verificado mediante pruebas funcionales. El documento se organiza en dos grandes bloques: primero, el modelo de negocio que da contexto y justifica la necesidad del sistema; segundo, el modelo de seguridad propiamente dicho, estructurado alrededor de la tríada de Confidencialidad, Integridad y Disponibilidad (CIA) y alineado a los dominios de control de la norma ISO/IEC 27001:2022.

Se incluye además la clasificación de las principales vulnerabilidades y amenazas identificadas durante el análisis del sistema, el control implementado para mitigar cada una, y una matriz de trazabilidad entre dichos controles y los dominios normativos aplicables, de manera que el modelo de seguridad resulte auditable: cualquier control declarado puede verificarse contra una implementación concreta y contra la norma que lo respalda.

1. Modelo de Negocio

1.1 Planteamiento del Problema (Situación actual)

Los equipos y agencias que administran cuentas de venta en Amazon gestionan simultáneamente varios frentes: campañas de publicidad PPC (Sponsored Products), el monitoreo de términos de búsqueda (Search Terms) y palabras clave (Keywords) que generan tráfico hacia sus productos, y el contenido de los listados (títulos, bullets, descripciones e imágenes) que determina la conversión de ese tráfico en ventas. En la práctica, gran parte de esta operación se realiza todavía mediante hojas de cálculo compartidas por correo electrónico o unidades de red, sin un sistema centralizado que controle quién puede ver o modificar cada tipo de información.

Esta forma de trabajo expone a la organización a riesgos concretos de seguridad de la información: no existe control de acceso (cualquier persona con el archivo puede modificar cifras de inversión publicitaria o el contenido de un listado), no hay autenticación más allá de una contraseña de correo, no queda registro de quién cambió qué ni cuándo (sin bitácora de auditoría), y los archivos Excel que circulan entre colaboradores pueden ser vector de inyección de fórmulas maliciosas si se abren sin cuidado. A esto se suma la ausencia de un segundo factor de autenticación y la imposibilidad de restringir el acceso de un colaborador nuevo a únicamente los módulos que su función requiere.

Estas debilidades no son hipotéticas: corresponden a categorías de riesgo reconocidas por el marco OWASP y por la norma ISO/IEC 27001 (control de acceso deficiente, falta de registro y monitoreo, gestión débil de identidad y autenticación). El presente proyecto responde a esta situación con el diseño e implementación de un sistema centralizado —AdScope— que reemplaza las hojas de cálculo sueltas por una aplicación web con control de acceso, autenticación reforzada y trazabilidad completa de las acciones críticas.

1.2 Objetivos

Objetivo General

Diseñar e implementar un sistema web de gestión de campañas PPC y de optimización SEO para productos de Amazon (AdScope), incorporando un modelo de seguridad de la información auditable, alineado a la tríada de Confidencialidad, Integridad y Disponibilidad (CIA) y a los dominios de control de la norma ISO/IEC 27001:2022.

Objetivos Específicos

- Implementar autenticación robusta con verificación en dos pasos (MFA/TOTP) y control de acceso basado en roles (RBAC), garantizando que un administrador no pueda auto-degradar su propio rol.
- Diseñar un control de acceso granular por módulo (permisos de "vista" o "editor"), administrable desde un panel de administración, bajo el principio de mínimo privilegio: todo usuario nuevo inicia sin acceso hasta que se le asigna explícitamente.

- Establecer una bitácora de auditoría inmutable que registre inicios de sesión, intentos fallidos, cambios de rol y de permisos, y acciones críticas sobre los datos, con usuario, dirección IP y marca de tiempo.
- Proteger la integridad de los datos cargados de forma masiva (importación de Excel) mediante saneamiento contra inyección de fórmulas y validación estricta de esquemas de entrada.
- Implementar controles de disponibilidad y resiliencia frente a ataques de fuerza bruta, incluyendo limitación de tasa de peticiones (rate limiting) y bloqueo temporal de cuentas.
- Desplegar la solución en infraestructura en la nube aplicando buenas prácticas de seguridad en el proceso de despliegue, sin degradar ninguno de los controles implementados.
- Documentar y auditar el cumplimiento de los controles implementados frente a la tríada CIA y los dominios aplicables de la norma ISO/IEC 27001.

1.3 Planificación de la Solución

La solución se estructuró bajo una arquitectura de tres capas desacopladas: un frontend en Angular (aplicación de página única), un backend en NestJS que expone una API REST propia para los módulos de negocio, y Supabase como plataforma de base de datos (PostgreSQL) y de autenticación como servicio. Esta separación permite aplicar controles de seguridad en capas independientes: reglas de acceso a nivel de base de datos (Row Level Security), reglas de autorización a nivel de API (guards de NestJS), y ocultamiento de funciones no autorizadas a nivel de interfaz.

El desarrollo se planificó de forma iterativa e incremental, por módulos funcionales, de manera que cada entrega agregara valor de negocio y, en paralelo, una capa de seguridad verificable:

1. Autenticación, registro y control de acceso basado en roles (RBAC).
2. Verificación en dos pasos (MFA/TOTP) y códigos de recuperación de un solo uso.
3. Bitácora de auditoría inmutable de acciones críticas.
4. Módulos funcionales de negocio: PPC, Search Terms, Listings, Keywords y Listing Builder.
5. Endurecimiento de integridad: saneamiento anti-inyección, validación estricta de entradas.
6. Controles de disponibilidad: limitación de tasa de peticiones y bloqueo de cuenta.
7. Permisos granulares por módulo y por usuario.
8. Seguridad de la cadena de suministro de software (SBOM, auditoría de dependencias).
9. Despliegue en producción preservando la totalidad de los controles de seguridad.
10. Documentación y auditoría final de cumplimiento.

2. Modelo de Seguridad

2.1 Planteamiento del Proyecto de Seguridad

El proyecto de seguridad busca convertir los riesgos descritos en la sección 1.1 en controles concretos, verificables y auditables, implementados directamente en el código del sistema AdScope. El planteamiento se organiza alrededor de la tríada CIA:

Confidencialidad: que solo las personas autorizadas —y únicamente en la medida de su función— puedan ver o modificar información sensible (cifras de inversión publicitaria, contenido de listados, datos de otros usuarios).

Integridad: que los datos no puedan ser alterados de forma no autorizada o maliciosa, ya sea por un usuario con intenciones indebidas o por un archivo cargado con contenido malicioso.

Disponibilidad: que el sistema permanezca operativo y resistente ante intentos de abuso (fuerza bruta, saturación de peticiones), sin sacrificar la experiencia de los usuarios legítimos.

Estos tres ejes se complementan con una capa de gobernanza basada en la norma ISO/IEC 27001:2022, que aporta el vocabulario y la estructura de controles (Anexo A) usada para verificar que ningún dominio relevante de seguridad de la información quedó sin cubrir.

2.2 Viabilidad Técnica y Operativa de la Solución

Viabilidad técnica

Todas las tecnologías utilizadas son de código abierto o cuentan con un nivel gratuito suficiente para un proyecto de este alcance (Supabase, Render y Vercel), lo que hace viable la implementación sin inversión en infraestructura propia. El stack elegido (Angular, NestJS, PostgreSQL) cuenta con documentación oficial extensa y es ampliamente utilizado en la industria, lo que reduce el riesgo técnico del proyecto.

Viabilidad operativa

El sistema se administra desde un panel web centralizado, sin requerir instalación de software en los equipos de los usuarios finales: basta un navegador con conexión a internet. La curva de aprendizaje es baja porque la interfaz reutiliza patrones ya conocidos (tablas, filtros, formularios), y la administración de accesos (roles y permisos por módulo) puede ser realizada por personal no técnico desde la pantalla de Administración.

Limitaciones reconocidas

Por tratarse de niveles gratuitos de los proveedores de nube, existen dos limitaciones documentadas y aceptadas conscientemente: (1) el backend en el plan gratuito de Render entra en reposo tras aproximadamente 15 minutos de inactividad, añadiendo una demora la primera petición tras el reposo; y (2) Supabase, en su plan gratuito, no ofrece recuperación a un punto exacto en el tiempo (Point-in-Time Recovery), únicamente respaldos diarios automáticos. Ambas limitaciones están

documentadas en el repositorio del proyecto junto con la ruta de mejora si el sistema pasa a un plan de pago.

2.3 Contexto Técnico de Trabajo

2.3.1 Hardware

El sistema se apoya íntegramente en infraestructura como servicio (IaaS/PaaS) provista en la nube, por lo que no requiere hardware físico dedicado por parte del equipo de desarrollo ni de la organización que lo adopte:

- Backend (API REST en NestJS): desplegado como servicio web administrado en Render.
- Frontend (aplicación Angular): desplegado y servido globalmente vía CDN en Vercel.
- Base de datos (PostgreSQL) y autenticación: gestionadas por Supabase.
- Del lado del cliente: cualquier dispositivo (computadora, tableta, teléfono) con un navegador web moderno y conexión a internet.

2.3.2 Software

- Angular 22 — framework de frontend (componentes standalone y signals).
- NestJS 12 — framework de backend para Node.js/TypeScript, expone la API REST propia.
- PostgreSQL (vía Supabase) — motor de base de datos relacional, con Row Level Security (RLS).
- Supabase Auth — gestión nativa de autenticación, sesiones y MFA (TOTP).
- Tailwind CSS + DaisyUI — sistema de diseño de la interfaz de usuario.
- bcryptjs — hashing de contraseñas y de códigos de recuperación de un solo uso.
- Helmet — cabeceras de seguridad HTTP (CSP, X-Frame-Options, HSTS, entre otras).
- @nestjs/throttler — limitación de tasa de peticiones (rate limiting).
- ExcelJS — procesamiento seguro de archivos de importación/exportación Excel.
- class-validator / class-transformer — validación estricta de datos de entrada (DTOs).
- CycloneDX — generación de un inventario de dependencias (SBOM) para la cadena de suministro.
- GitHub Actions — automatización de auditoría de dependencias en cada cambio de código.

2.3.3 Metodología, estándar, etc.

- Tríada CIA (Confidencialidad, Integridad, Disponibilidad) como marco rector del modelo de seguridad.
- Norma ISO/IEC 27001:2022, Anexo A, como referencia de dominios de control (ver sección 2.7).
- Principio de mínimo privilegio y "seguridad por defecto": todo usuario nuevo inicia sin ningún permiso hasta que se le asigna explícitamente.
- Referencias complementarias de buenas prácticas: OWASP Top 10 y OWASP CSV/Formularia Injection Prevention.

- Metodología de desarrollo iterativo e incremental, por módulos funcionales (ver plan de ejecución, sección 2.5).

2.4 Otros Recursos y Consideraciones

- Recursos humanos: dos integrantes, con roles de desarrollo full-stack compartidos entre frontend, backend y base de datos.
- Recursos técnicos: cuentas de servicio en Supabase, Render, Vercel y GitHub (todas dentro de sus niveles gratuitos); repositorio Git para control de versiones.
- Separación de privilegios de acceso a la base de datos: la llave "de servicio" (service role), que ignora las políticas de Row Level Security, permanece únicamente como variable de entorno del backend y nunca se expone al navegador; el frontend usa exclusivamente una llave pública de alcance restringido.
- Manejo de datos sensibles de negocio: cifras de inversión y ventas publicitarias, y contenido de listados de producto, tratados bajo el mismo estándar de control de acceso que credenciales de usuario.
- Consideración de continuidad: toda decisión de seguridad se validó contra el requisito explícito del equipo de no perder funcionalidad ni controles ya implementados al desplegar a producción.

2.5 Plan de Ejecución

El plan de ejecución replica, con mayor detalle de seguridad, las fases descritas en la sección 1.3:

1. Fase 1 — Autenticación y RBAC base: login, registro, roles admin/usuario, regla de no auto-degradación de rol del propio administrador.
2. Fase 2 — Verificación en dos pasos (MFA/TOTP) obligatoria para administradores, con códigos de recuperación de un solo uso, hasheados con bcrypt.
3. Fase 3 — Bitácora de auditoría inmutable: inicios de sesión, cambios de rol, y acciones críticas, con IP real del cliente y marca de tiempo.
4. Fase 4 — Módulos funcionales (PPC, Search Terms, Listings, Keywords, Listing Builder), con importación masiva vía plantilla Excel y control de lo importado.
5. Fase 5 — Endurecimiento de integridad: saneamiento anti-inyección de fórmulas, validación estricta de DTOs en toda la API, validación de URLs de imágenes.
6. Fase 6 — Controles de disponibilidad y resiliencia: limitación de tasa de peticiones global, bloqueo de cuenta tras intentos fallidos repetidos.
7. Fase 7 — Permisos granulares por módulo y por usuario (vista/editor), con acceso nulo por defecto.
8. Fase 8 — Seguridad de la cadena de suministro: generación de SBOM y auditoría automatizada de dependencias en cada cambio de código.
9. Fase 9 — Despliegue en producción (Render, Vercel, Supabase), verificando que ningún control de seguridad se perdiera en el proceso.

10. Fase 10 — Documentación y auditoría final de cumplimiento frente a la tríada CIA y la norma ISO/IEC 27001.

2.6 Clasificación de Vulnerabilidad y/o Amenaza

La siguiente matriz resume las principales vulnerabilidades y amenazas identificadas durante el análisis de seguridad del sistema, clasificadas según la categoría de la tríada CIA que comprometen, el riesgo concreto que representan si no se atienden, y el control efectivamente implementado para mitigarlas. Cada control listado corresponde a una implementación verificable en el código fuente del proyecto, no a una medida meramente declarativa.

Vulnerabilidad / Amenaza	Categoría CIA afectada	Riesgo si no se mitiga	Control implementado
Credenciales débiles o contraseñas filtradas	Confidencialidad	Acceso no autorizado mediante adivinación o reutilización de contraseñas filtradas en otros servicios	Política de contraseñas de Supabase Auth con verificación contra bases de contraseñas filtradas conocidas
Ataque de fuerza bruta contra el inicio de sesión	Confidencialidad / Disponibilidad	Adivinación de contraseña por intentos repetidos y automatizados	Bloqueo de la cuenta tras 5 intentos fallidos en una ventana de 15 minutos, verificado contra la bitácora de auditoría
Compromiso de una cuenta sin segundo factor	Confidencialidad	Suplantación de identidad de un administrador con acceso total al sistema	Verificación en dos pasos (MFA/TOTP) obligatoria para el rol administrador, con códigos de recuperación de un solo uso
Escalamiento de privilegios (auto-promoción de rol)	Confidencialidad / Integridad	Un usuario se auto-assigna el rol de administrador	Regla explícita: un administrador no puede modificar su propio rol; los cambios de rol solo se ejecutan desde el backend con la llave de servicio
Acceso de un usuario a módulos fuera de su función	Confidencialidad	Un usuario visualiza o modifica datos de un módulo que no le corresponde	Control de acceso granular por módulo (vista/editor) con acceso nulo por defecto, verificado en frontend, backend y base de datos
Inyección de fórmulas (CSV/Excel Injection)	Integridad	Ejecución de fórmulas maliciosas al reabrir un archivo exportado en Excel	Saneamiento de todo texto cargado que inicie con "=", "+", "-", "@", tabulador o retorno de carro, antes de almacenarlo
Carga de archivos Excel con contenido malicioso	Integridad / Disponibilidad	Explotación de vulnerabilidades conocidas de librerías de parseo de hojas de cálculo	Uso de ExcelJS en lugar de librerías con vulnerabilidades documentadas de contaminación de prototipos y ReDoS
URLs maliciosas en campos de imagen de un listado	Integridad	Ejecución de scripts mediante esquemas de URL no válidos (p. ej. "javascript:")	Validación estricta de URL (solo protocolos http/https) y límite de cantidad de imágenes por listado
Ausencia de trazabilidad de acciones críticas	Integridad	Imposibilidad de investigar un incidente de seguridad o un cambio indebido	Bitácora de auditoría inmutable (sin permisos de actualización ni borrado) con usuario, IP y marca de tiempo
Saturación de la API con peticiones excesivas	Disponibilidad	Degradación o caída del servicio para todos los usuarios	Limitación de tasa de peticiones (100 solicitudes por minuto por IP)

Vulnerabilidad / Amenaza	Categoría CIA afectada	Riesgo si no se mitiga	Control implementado
Cabeceras HTTP inseguras	Confidencialidad / Integridad	Explotación mediante clickjacking o interpretación incorrecta de tipos de contenido	Cabeceras de seguridad HTTP (CSP, X-Frame-Options, X-Content-Type-Options, HSTS) mediante Helmet
Dependencias de terceros con vulnerabilidades conocidas	Integridad / Disponibilidad	Explotación de una vulnerabilidad ya publicada en una librería utilizada por el sistema	Auditoría automatizada de dependencias e inventario de software (SBOM) en cada cambio de código
Pérdida de datos sin punto de restauración exacto	Disponibilidad / Integridad	Imposibilidad de restaurar el sistema a un instante preciso tras una corrupción de datos	Respallos diarios automáticos; recuperación a un punto exacto (PITR) pendiente por costo del plan gratuito, riesgo aceptado y documentado
Sesión abierta en un dispositivo desatendido	Confidencialidad	Acceso no autorizado si el usuario se aleja de un equipo con sesión iniciada	Cierre de sesión automático por inactividad
Exposición de la llave de servicio (service role)	Confidencialidad	Acceso total a la base de datos, sin restricciones de RLS, si la llave se filtra	La llave de servicio nunca se expone al frontend; vive únicamente como variable de entorno en el servidor backend

2.7 Implementación de Estándar ISO/IEC 27001:2022

El modelo de seguridad se alineó contra los dominios de control del Anexo A de la norma ISO/IEC 27001:2022, seleccionando aquellos aplicables a un sistema de software de este alcance. La siguiente matriz de trazabilidad vincula cada control normativo con su implementación concreta dentro del proyecto:

Control ISO/IEC 27001:2022	Descripción del control	Implementación en el proyecto
A.5.15 — Control de acceso	Establecer reglas para controlar el acceso físico y lógico a la información y a los recursos de tratamiento de la información.	Control de acceso basado en roles (admin/usuario) y permisos granulares por módulo (vista/editor), con acceso nulo por defecto para usuarios nuevos.
A.5.17 — Información de autenticación	Asignar y gestionar la información de autenticación mediante un proceso controlado.	Verificación en dos pasos (MFA/TOTP) obligatoria para administradores; contraseñas gestionadas por Supabase Auth con verificación contra filtraciones conocidas.
A.5.18 — Derechos de acceso	Proveer, revisar, modificar y eliminar los derechos de acceso de acuerdo con la política de control de acceso.	Panel de administración donde el rol y los permisos por módulo de cada usuario pueden asignarse, modificarse o revocarse en cualquier momento.
A.8.15 — Registro (logging)	Producir, almacenar, proteger y analizar registros que documenten actividades, excepciones, fallas y otros eventos relevantes.	Bitácora de auditoría inmutable (sin permisos de actualización ni borrado) que registra inicios de sesión, intentos fallidos, cambios de rol y de permisos, con usuario, IP y marca de tiempo.
A.8.16 — Actividades de monitoreo	Monitorear redes, sistemas y aplicaciones para detectar comportamiento anómalo y evaluar posibles incidentes.	Registro de intentos fallidos de inicio de sesión por cuenta, con bloqueo automático tras superar el umbral definido.
A.8.24 — Uso de criptografía	Definir e implementar reglas para el uso efectivo de la criptografía, incluyendo la gestión de claves.	Contraseñas y códigos de recuperación almacenados exclusivamente como hash (bcrypt), nunca en texto plano.
A.8.25 — Ciclo de vida de desarrollo seguro	Establecer reglas para el desarrollo seguro de software y sistemas.	Validación estricta de entradas mediante DTOs en toda la API, saneamiento de datos cargados, y revisión de código orientada a seguridad en cada módulo.
A.8.28 — Codificación segura	Aplicar principios de codificación segura al desarrollo de software.	Uso de librerías con historial de seguridad verificado (p. ej. ExcelJS), manejo explícito de excepciones y defensa en profundidad (RLS + guards de backend + control en la interfaz).
A.8.29 / A.8.31 — Pruebas y separación de entornos	Ejecutar pruebas de seguridad durante el desarrollo y separar los entornos de desarrollo, prueba y producción.	Verificación funcional de cada control antes de su despliegue; separación de configuración entre entorno local y producción mediante variables de entorno.

Control ISO/IEC 27001:2022	Descripción del control	Implementación en el proyecto
A.5.29 — Seguridad durante la interrupción	Mantener un nivel adecuado de seguridad de la información durante una interrupción del servicio.	Limitación de tasa de peticiones (rate limiting) para preservar la disponibilidad del servicio ante abuso o saturación.
A.5.30 — Preparación de las TIC para la continuidad del negocio	Planificar, implementar y verificar la disponibilidad de las tecnologías de información para la continuidad del negocio.	Respallos diarios automáticos de la base de datos; recuperación a un punto exacto (PITR) identificada como mejora futura sujeta a la contratación de un plan pago.
A.5.9 — Inventario de activos de información	Desarrollar y mantener un inventario de la información y otros activos asociados.	Inventario documentado de módulos, tablas de base de datos y flujos de datos del sistema (ver este documento y el repositorio del proyecto).

De manera complementaria, el proyecto también puede leerse bajo las cinco funciones del NIST Cybersecurity Framework: Identificar (inventario de activos y de vulnerabilidades, sección 2.6), Proteger (RBAC, permisos granulares, MFA, saneamiento de datos), Detectar (bitácora de auditoría, registro de intentos fallidos), Responder (bloqueo automático de cuenta, alertas mediante la bitácora) y Recuperar (respaldos automáticos de la base de datos, procedimiento de recuperación documentado). Esta doble lectura (ISO 27001 y NIST CSF) refuerza el carácter auditable del modelo: cualquier control puede rastrearse hacia al menos un marco normativo reconocido.

Conclusiones y Recomendaciones

Conclusiones

- Es posible operacionalizar la tríada CIA y los dominios de control de ISO/IEC 27001 en un sistema de software real, con controles verificables en código, y no únicamente en documentos de política.
- El principio de mínimo privilegio —acceso nulo por defecto hasta que se asigna explícitamente— resultó práctico de implementar y ofrece a la organización un control fino sobre quién puede ver o modificar cada módulo de información.
- La defensa en profundidad (control de acceso replicado en base de datos, backend y frontend) demostró su valor: un control ausente en una sola capa no habría sido suficiente para cubrir todos los caminos de acceso al sistema.
- El proceso de despliegue a producción evidenció que preservar los controles de seguridad requiere verificación activa en cada paso (por ejemplo, mantener sincronizadas las URLs autorizadas entre el proveedor de autenticación y el de hospedaje del frontend); un descuido en ese proceso puede introducir brechas no previstas en el diseño original.
- Existen limitaciones honestas y documentadas (ausencia de recuperación a un punto exacto en el plan gratuito, posibilidad de que un cliente distinto al frontend oficial evada el bloqueo de cuenta) que no invalidan el modelo, pero sí delimitan su alcance actual y deben comunicarse con transparencia a cualquier interesado.

Recomendaciones

- Migrar a un plan de pago de Supabase que incluya recuperación a un punto exacto (Point-in-Time Recovery), para reducir el tiempo objetivo de recuperación ante un incidente de integridad de datos.
- Incorporar un mecanismo de CAPTCHA (por ejemplo, hCaptcha o Cloudflare Turnstile) en el formulario de inicio de sesión, para cerrar la brecha residual de fuerza bruta que un cliente distinto al frontend oficial podría explotar.
- Establecer un monitoreo activo de disponibilidad (uptime) sobre el backend, dado que el plan gratuito actual entra en reposo por inactividad.
- Definir un procedimiento formal y documentado de respuesta a incidentes, incluyendo pasos concretos ante la sospecha de una llave de servicio filtrada.
- Realizar revisiones periódicas (por ejemplo, trimestrales) de los roles y permisos asignados a cada usuario, retirando accesos que ya no correspondan a su función actual.
- Evaluar, conforme crezca la base de usuarios, extender la obligatoriedad del segundo factor de autenticación (MFA) más allá del rol administrador.

Glosario

RBAC (Role-Based Access Control): Modelo de control de acceso en el que los permisos se otorgan en función del rol asignado a un usuario (por ejemplo, "administrador" o "usuario").

MFA / 2FA: Autenticación multifactor / de dos factores: mecanismo que exige, además de la contraseña, un segundo elemento de verificación (en este proyecto, un código TOTP generado por una aplicación autenticadora).

TOTP (Time-based One-Time Password): Contraseña de un solo uso, generada a partir de una clave secreta compartida y de la hora actual, válida por un periodo breve.

RLS (Row Level Security): Mecanismo de PostgreSQL que permite restringir, fila por fila, qué registros de una tabla puede leer o modificar un usuario según reglas definidas.

Tríada CIA: Modelo clásico de seguridad de la información compuesto por Confidencialidad, Integridad y Disponibilidad.

ISO/IEC 27001: Norma internacional que especifica los requisitos para establecer, implementar, mantener y mejorar un sistema de gestión de seguridad de la información (SGSI).

SBOM (Software Bill of Materials): Inventario formal de los componentes de software (dependencias y librerías) que forman parte de una aplicación, usado para gestionar riesgos de la cadena de suministro.

CORS (Cross-Origin Resource Sharing): Mecanismo del navegador que restringe qué dominios distintos al de origen pueden hacer peticiones a una API.

Rate limiting (limitación de tasa): Control que restringe la cantidad de peticiones que un mismo origen puede hacer a un sistema en un periodo de tiempo determinado, para prevenir abuso o saturación.

Hash / Hashing: Función matemática de un solo sentido que transforma un dato (por ejemplo, una contraseña) en una cadena de longitud fija, de la cual no es posible recuperar el valor original.

CSP (Content Security Policy): Cabecera HTTP que restringe desde qué orígenes un navegador puede cargar scripts, estilos u otros recursos, para mitigar ataques de scripting entre sitios.

XSS (Cross-Site Scripting): Vulnerabilidad que permite a un atacante inyectar y ejecutar código de script en el navegador de otro usuario.

Inyección de fórmulas (CSV/Formula Injection): Técnica de ataque en la que se inserta una fórmula maliciosa en un archivo de hoja de cálculo, que se ejecuta automáticamente al abrirlo en programas como Excel.

PITR (Point-in-Time Recovery): Capacidad de restaurar una base de datos al estado exacto en que se encontraba en un instante específico del pasado, y no solo al de un respaldo periódico.

DTO (Data Transfer Object): Objeto que define y valida la forma exacta de los datos que entran o salen de una API, usado para rechazar datos con formato inesperado o malicioso.

API REST: Estilo de arquitectura para servicios web en el que los recursos se identifican mediante URLs y se manipulan usando los métodos estándar del protocolo HTTP.

PaaS (Platform as a Service): Modelo de servicio en la nube en el que el proveedor gestiona la infraestructura y el entorno de ejecución, y el desarrollador solo despliega su aplicación.

Bibliografía

1. International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.
2. National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. U.S. Department of Commerce.
3. OWASP Foundation. (2021). OWASP Top 10:2021 — The Ten Most Critical Web Application Security Risks. <https://owasp.org/Top10/>
4. OWASP Foundation. (s.f.). CSV Injection. OWASP Community Pages. https://owasp.org/www-community/attacks/CSV_Injection
5. Supabase Inc. (2026). Supabase Documentation — Auth, Row Level Security y Multi-Factor Authentication. <https://supabase.com/docs>
6. Angular Team, Google. (2026). Documentación oficial de Angular. <https://angular.dev>
7. NestJS. (2026). Documentación oficial de NestJS. <https://docs.nestjs.com>
8. Render Services, Inc. (2026). Render Documentation. <https://render.com/docs>
9. Vercel Inc. (2026). Vercel Documentation. <https://vercel.com/docs>
10. Universidad Mariano Gálvez de Guatemala. (2026). Materiales del curso Seguridad y Auditoría de Sistemas: Sistema de Autenticación, Ciber-Resiliencia, Modelo de Negocio y Solución de Seguridad Informática.